Summary of Differences from the Conference Version

Formal Analysis and Fixing of Third-Party Online Payment Protocols
Yongkang Xiao, Jing Chen, Min Shi, Kun He, Qiyi Deng, and Ruiying Du

Earlier publication. Y. Xiao, J. Chen, M. Shi, K. He, Q. Deng, and R. Du, "When Authorization Loses Its Meaning: Breaking and Fixing Third-Party Online Payments," in *Proceedings of the 35th USENIX Security Symposium (USENIX Security '26)*, 2026. The conference version is uploaded as a previously published file.

Overview. The conference version formally analyzed six third-party online payment protocols of Alipay and PSP-B, identified order tampering attacks and a new attack variant based on Android Intent hijacking, measured its prevalence, and proposed a countermeasure based on per-user key pairs. That countermeasure follows trust on first use: the merchant generates a key pair for each user, and the payment application binds it to the user at the first payment, so the first payment to each merchant remains open to order tampering (its verification reported IA-O2 as violated in the initial stage). This manuscript replaces it with a new countermeasure, *Sealed Checkout Code* (SCC), which protects every payment, including the first, in a single protocol run without per-user keys, and verifies it formally.

New material.

1. **New countermeasure (Section VII-B to VII-D, Fig. 6).** Design goals; the SCC protocol on top of payment pattern B, in which the merchant frontend seals a fresh nonce to the payment system together with the merchant identifier, the prepayment identifier, and the user's merchant account, and the user confirms the payment by entering a short code derived from the nonce; the rationale for the direction of the code; integration; and a security analysis of the attacker's options.
2. **Formal verification of SCC (Section VII-E, Table II).** A Tamarin model of SCC with the channel rules, tactics, and lemmas of the original analysis. All five security properties (IA-O1, IA-O2, IA-UA, IA-R1, IA-R2) are verified under the Base assumption, in which both external channels are insecure; this covers the SecureMS and SecurePS assumptions. A control experiment applies the commit point used for SCC to all six original protocols under all three channel assumptions and confirms that IA-O2 remains falsified in all 18 models.
3. **New related work (Section VIII-D).** A comparison of SCC with transaction authentication mechanisms: PSD2 dynamic linking, EMV 3-D Secure, Secure Payment Confirmation, attacks on mobile two-factor authentication and PSD2 banking apps, and short authenticated strings.
4. **Updated discussion (Section VII-F).** Advantages and limitations of SCC.

Revised material.

- The abstract, the third contribution, and the title reflect the new countermeasure; the introduction states the relation to the conference version.
- The security properties are presented as one injective-agreement template with the event pair of each property, and the template now includes the ordering condition $\#j < \#i$ used in the models.

- Several passages are condensed to fit the journal format: the TAMARIN background, the payment scenarios, the cause analysis, the description of the Android vulnerability, and the related work on payment systems.
- Typographical and consistency errors are corrected, including an incomplete sentence in the threat model and the share of vulnerable applications in the abstract (25%, as in the body).

Removed material.

- The conference countermeasure and its verification results.
- The appendices (payment scenario illustrations and the detailed Alipay and PSP-B protocol figures) and the USENIX artifact appendix; the formal models remain available in the public repository cited in Section IV.
- The venue-specific sections on ethical considerations and open science.

Unchanged material. The protocol models, security property definitions, verification results of the six protocols (Table I), attack variants, real-world attack, measurement study, and responsible disclosure are carried over from the conference version, with the editorial changes listed above.